VIRS original system: inventory and reasons for change

What VIRS does

VIRS helps teachers, students and researchers judge how difficult a text is by looking at its vocabulary. The original application lets users:

- **Analyze a text:** typed, a Word document, a PDF, or a photo of a page.
- **See the enhanced text:** every word colored by the research word list it belongs to (K1, K2, K3, Academic, Basic Academic, STEM, high, medium and low frequency, or off-list), with a definition on click.
- **See statistics:** Flesch reading-ease score, reading level, and word counts and percentages per list, with charts.
- **Browse word lists:** search by list and grade (Kindergarten–12), and download lists as CSV/Excel.
- **Translate** text (iTranslate).
- **Manage an account:** register, log in, edit the profile, change or recover the password, delete the account.
- **Administer the word database:** add, edit, delete, bulk CSV upload, delete a whole list.
- **Other pages:** contact form, references, "Cite us", donate link, and a language switch for navigation labels (English, Spanish, Farsi).
- **Vocabulary tests:** built but hidden. The sidebar comments them out ("TEMPORARILY HID VOCABULARY TESTS AT P.O's REQUEST"), and the test banks are marked "THIS SECTION IS NOT DONE YET".

How the original project was divided

VIRS was built as **two separate projects** in one parent folder (`virs/Code/` , per the project READMEs), plus a database and several external services.

Part	Original project	Technology	Role
Frontend	`VIR-Frontend` (now `apps/web`)	Angular 4 single-page app, TypeScript 2.3, Bootstrap 4, SCSS	All screens; calls the backend's `/api/*` endpoints

Part	Original project	Technology	Role
Backend	`VIR-Backend` (now `apps/api`)	Spring Boot 1.5 REST API, Java 8, Maven	Text analysis, file parsing and OCR, dictionary lookups, word lists, user accounts, admin
Database (production)	AWS	MySQL (credentials encrypted with Jasypt in `application.yml`)	Word lists (about 42,000 rows per the schema's `AUTO_INCREMENT`), users, password-reset tokens
Database (development)	Each developer's machine	Local Postgres (`localhost:5432/vir`), schema created by Hibernate (`ddl-auto: update`)	Local testing
Word-list data	`VIR-Backend/src/main/resources/*.sql`	MySQL SQL scripts (`schema.sql`, `data.sql`, `queriesEWL.sql`, `updateGrades.sql`)	Loaded into the database by hand

How the pieces connected

During development, the two projects ran side by side:

```
Browser → Angular dev server (localhost:4200) ──proxy /──▶ Spring Boot (localhost:8080) ──▶ local database
```

`VIR-Frontend/proxy.conf.json` forwards every request to port 8080, and a `dev`-only CORS configuration in the backend allows the cross-origin calls.

In production, they shipped as one unit:

```
Browser → AWS Elastic Beanstalk (nginx) → Spring Boot jar ─┬─ /api/*   → REST controllers → MySQL
                                                           └─ other URLs → Angular build (inside the jar)
```

1. The Angular app was built (`ng build --prod`) and its output copied into `VIR-Backend/src/main/resources/static/`.
2. Maven packaged the API and the frontend into a single jar. The `prod` profile excluded the SQL scripts and assembled an Elastic Beanstalk bundle with a generated `Procfile`.
3. `AngularRedirectController` forwarded any non-file URL to `index.html`, so Angular's routes (e.g. `/search-words`) worked on refresh.

4. An `.ebextensions` nginx setting raised the upload limit above 1 MB so documents and images could be analyzed.

External services the original app depends on

Service	Used for	Current status
AWS Elastic Beanstalk	Hosting the jar	Paid, always-on server
MySQL on AWS	Production data	Credentials only readable with the Jasypt vault key
AWS Textract (Java SDK v1)	Text from images	**Not configured — this is why image upload fails** (6.2 #1); SDK v1 is end-of-support
Tesseract OCR (native install)	Text inside PDFs	Must be installed on the server (`TESSERACT_PATH`, `TESSDATA_PREFIX`)
OpenCV 3.2 (bundled native library)	Image clean-up before OCR	No ARM support (verified)
Oxford Dictionaries API v1	Definitions	Discontinued by Oxford
Wiktionary API	Definitions (the source the UI actually uses)	**Now rejects the app's requests with HTTP 403** (6.2 #3)
SendGrid	Password-reset emails and error reports	API key lost since 2021 (per the backend README)
Gmail SMTP	Configured in `application.yml` (`SendEmail` service)	Never called by the app; its password was committed to the repository
Google Translate (unofficial endpoint)	iTranslate and the image flow, called from the browser	Unofficial, rate-limited (HTTP 429 observed)
formcarry.com	Contact form	Third-party form service
Adobe Typekit, PayPal	Header font, donate link	External links

---

What works

The application runs and the great majority of it works. Exercised in the browser against the running backend:

Feature	Result
Dashboard	✅ Loads
Analyze typed text → **Enhanced Text**	✅ 106 words colour-coded by list in the sample text

Feature	Result
Analyze typed text → **Statistics**	✅ Readability score, level ("Upper intermediate"), per-list table and both charts
Word document upload (.docx)	✅ 16 words extracted and analyzed
PDF upload	✅ 7 words extracted and analyzed
Image upload	❌ "The file is not readable" (6.2 #1)
Search word lists	✅ Lists load; prefix search for "ab" returned *about, above*
Download an individual list (K1)	✅ 999 words
Download a group of lists (K1–K3)	✅ 1,999 words, both populated lists included
Register an account	✅
Log in	✅
My Profile	✅
Change password	✅ (`PATCH` → 200)
Delete account	✅ Server returns 204 and the UI confirms deletion
Admin panel (after the Spring Security login)	✅ Search works; add/edit/delete work, with the caveat in 6.2 #2
iTranslate	✅ "Good morning, how are you?" → "Buenos días, ¿cómo estás?"
Contact and References pages	✅
Definition pop-up	❌ "We couldn't find the definition" (6.2 #3)
Results after a page refresh	❌ "Opps! Please go back" (6.2 #7)

What's broken

6.1 What it takes to run it (observed)

Getting the application running took most of a working session. Each item below is a hard prerequisite — the app stops at each one in turn until it is satisfied:

1. **Tesseract OCR must be installed locally.** Without `TESSDATA_PREFIX` and `TESSERACT_PATH`, start-up aborts with `Could not resolve placeholder 'TESSDATA_PREFIX'` — even for features that never touch OCR.
2. **The Jasypt vault key must be supplied.** `DecryptionException: Decryption of Properties failed`. The Oxford and production database credentials are encrypted inside `application.yml`, so `APP_ENCRYPTION_PASSWORD` has to come from outside the repository. For this audit the encrypted values were bypassed with dummy environment variables. **If that key is lost, the production credentials cannot be recovered.**

3. **The processor must be x86.** `UnsupportedOperationException: Architecture "aarch64" is not supported` — OpenCV 3.2.0 (2016) ships no ARM binaries. On Apple Silicon the backend only started under **Rosetta emulation with an x86 JDK**. Any ARM machine or ARM cloud instance cannot run it natively.
4. **The database must be MySQL.** The committed configuration points the datasource at Postgres, but on Postgres Hibernate's generated `create table user (… creation_date DATETIME … locked BIT DEFAULT 0 …)` is rejected with `syntax error at or near "user"`: `user` is reserved there and those column types are MySQL-only. Accounts therefore work only on MySQL, and the `data.sql` / `updateGrades.sql` seed scripts are MySQL-only as well.
5. **A modern MySQL needs the connection relaxing.** MySQL 26.7 no longer offers the authentication plugin the 2018 connector expects, and the 2018 connector rejects the server's certificate. The connection only succeeded with `useSSL=true&verifyServerCertificate=false&allowPublicKeyRetrieval=true` — a weakened TLS setting.

None of this is a defect in the application's logic. It is the cost of keeping it alive: a specific processor, a specific database, a native OCR install, a secret key, and two runtimes that no longer receive security updates.

Defects

Ordered by how much they matter. "Observed" means reproduced in the running application during this audit.

#	Problem	Evidence	Cause
1	**Image upload fails.** The UI shows "Oh snap! The file is not readable."	**Observed.** Backend log: `com.amazonaws.SdkClientException: Unable to find a region via the region provider chain.`	Image analysis calls **AWS Textract**, which needs an AWS region and credentials in the server's environment. None are configured. The failure is swallowed and an empty result returned, so the UI reports an unreadable file rather than a configuration problem. **It is a configuration issue, not broken code**.
2	**Adding a word to a second list silently removes it from the first.**	**Observed** end to end: "water" was in K1; adding it to STEM in the admin panel showed "water is added to stem category", after which the database held **only** `water → stem`. K1 quietly lost a word.	The admin save looks a word up by its value alone and overwrites that row instead of inserting a new one. Repeated use erodes the word lists, and the UI reports success each time.

#	Problem	Evidence	Cause
3	**Dictionary definitions never load.** Every lookup shows "We couldn't find the definition, please try another word."	**Observed:** `GET /api/entries/book?source=WIKI` → 503. The underlying cause, reproduced from the app's own Java runtime: Wiktionary replies **HTTP 403**.	The app sends no User-Agent header, and Wikimedia's API rejects such requests. A separate, older problem sits behind it: Wiktionary's markup has since changed from `<h2><span id="English">` to `<h2 data-mw-anchor="English">`, which the cleaner does not recognise, so even a successful response would be returned unfiltered — every language section included (the live page for "book" now carries Beja, Dutch and others).
4	**Words followed by punctuation are not recognised, and hyphenated entries never match.**	**Observed:** analyzing `books. book books co-worker coworker` returned *books.* → off-list, *book* → K1, *books* → K1, *co-worker* → off-list, *coworker* → off-list — although the word list itself contains hyphenated entries such as `super-power` and `self-review`.	Singularization runs before punctuation is stripped, and hyphens are removed from the text but kept in the stored list. Any word ending a sentence is therefore counted as off-list, which inflates the "Names & off-list" figure in every analysis.
5	**Basic Academic words are dropped from the statistics.**	**Observed:** a word whose only list is `baw` is shown correctly in the coloured text, yet four analyzed words produced a reported total of three.	The counting code has buckets for every list except Basic Academic, and the total is the sum of those buckets. With the current data the effect is hidden — all 200 `baw` words also belong to another list, and the conflict rule always prefers the other one — but any Basic-Academic-only word vanishes from the totals and percentages.
6	**Word lists are downloaded onto the server's disk.**	**Observed:** after the audit, `K1.csv`, `K1-K2-K3.csv` and `awl-baw.csv` were sitting in the backend's working directory.	Each download writes a CSV named after the requested lists into the server's working folder. Two users downloading the same list at once write to the same file.
7	**Refreshing the results page loses the analysis** ("Opps! Please go back").	**Observed.**	Results are held only in memory in the browser, so any refresh, shared link or back-navigation discards them and the text must be analyzed again.

#	Problem	Evidence	Cause
8	**"Download List" on the search page exports only what is on screen.**	**Observed:** with 2 rows displayed after a search, the downloaded `WordList.xlsx` contained those 2 rows.	The export is generated from the rendered HTML table rather than from the database.
9	Password-reset emails and error reports are never delivered.	**Code-level** (not testable here: no SendGrid key).	Both go through SendGrid, whose API key has been lost since 2021 (per the backend README), and SendGrid is forced into sandbox mode unless `PROD=1`. The Gmail sender configured in `application.yml` is never actually called.
10	Oxford dictionary lookups cannot work.	**Code-level.**	The Oxford Dictionaries API v1 has been discontinued. Only the Wiktionary source is reachable from the UI in any case.
11	A readability score that lands between two bands is labelled "Beginner".	**Code-level.**	The level bands cover whole numbers only, so scores in the gaps 29–30, 59–60, 69–70 and 79–80 fall through to the default. Roughly 4% of the range is affected.
12	Two consecutive spaces start a new paragraph in the enhanced text.	**Observed:** double spaces in submitted text produced empty tokens, which the UI renders as line breaks.	Every whitespace character is treated as a token boundary, and empty tokens are drawn as breaks.
13	The Textract monthly spend limit and the iTranslate character limit do nothing.	**Code-level.**	The Textract counter lives in memory, so it resets on every restart and is per-server; the iTranslate "characters left" counter always resets to 1,000.
14	Translation depends on an unofficial endpoint.	**Observed working** during the audit ("Buenos días, ¿cómo estás?"), but an **HTTP 429 rate-limit response** was recorded from this machine on an earlier attempt.	The browser calls an undocumented Google endpoint directly, with no agreement or quota.

Security problems

#	Problem	Evidence
1	**Any visitor can read any user's password.**	`GET /api/user/adituser` with no authentication returned the full record, including `"password":"U2FsdGVkX1+…"`. That value is AES-encrypted with a key hardcoded in the JavaScript bundle (`7061737323313233`), so it can be decrypted by anyone who opens the site. Login works by downloading this value and comparing it in the browser.
2	**The entire user list is public.**	`GET /api/user` with no authentication returned every user with their passwords and email addresses. Only `/api/admin/**` is protected.
3	**Anyone can modify anyone's account.**	An unauthenticated `PATCH /api/user/adituser` changed the account's name to "HACKED BY ANYONE" and its email to an attacker-controlled address; the change was accepted with HTTP 200 and persisted.
4	Passwords travel inside URLs.	`DELETE /api/user/{user}/{password}` and `POST /recovery_password?token=…&password=…` place credentials in paths and query strings, where they are recorded in server and proxy logs.
5	Password-reset endpoints reveal which accounts exist, and reset tokens never expire.	Recovery returns 404 for an unknown user, and no expiry is ever applied to an issued token.
6	Admin is a single shared username and password held in Spring configuration, and the Gmail SMTP password was committed to the repository in plain text.	Access cannot be granted or revoked per person, and the mail account must be rotated.
7	Conflicting and outdated libraries.	Two versions of opencsv (2.0 and 3.3) are bundled together; `spring-context-support` 3.1.1 is mixed with Spring 4.3.10; Jackson 2.8.9 and Tomcat 8.5.16 are years behind published security fixes.

Dependency inventory

Languages, runtimes and tools

Item	Version	Notes
Java	8 (`java.version` 1.8)	Required by Spring Boot 1.5
Maven	3.9.9 (wrapper 3.3.2)	Via `./mvnw`
TypeScript	2.3.4	Frontend
Node.js	8.x (verified 8.17.0)	Build needs Node ≤16 (OpenSSL); dev server needs Node <12 (`process.binding`); Node 8 is end-of-life (Dec 2019)

Item	Version	Notes
Sass	`node-sass` (original)	No longer installs on current Node/arm64; Dart Sass 1.32.13 was substituted to run it today
SQL	MySQL dialect (production scripts), Postgres (local development)	

7.2 Backend (`VIR-Backend`): Spring Boot 1.5.6, resolved versions from the built jar

Area	Library	Version
Framework	spring-boot (starter-parent)	1.5.6.RELEASE (end-of-life Aug 2019)
	spring-core / spring-web / spring-orm	4.3.10.RELEASE
	spring-context-support	3.1.1.RELEASE (conflicts with Spring 4.3)
	spring-security-core	4.2.3.RELEASE
	spring-data-jpa	1.11.6.RELEASE
	spring-boot-starter-mail / javax.mail	1.5.6 / 1.5.6
Web server	tomcat-embed-core	8.5.16 (Tomcat 8.5 end-of-life Mar 2024)
Persistence	hibernate-core	5.4.18.Final (forced; Boot 1.5 expects 5.0)
	hibernate-validator	5.3.5.Final
	HikariCP	2.5.1
	mysql-connector-java	5.1.47
	postgresql	42.2.27
	sqlite-jdbc	3.15.1
JSON / config	jackson-databind	2.8.9
	snakeyaml	1.17
	jasypt / jasypt-spring-boot-starter	1.9.2 / 1.16
API docs	springfox-swagger2 / swagger-ui	2.7.0
Text & files	tika-core / tika-parsers	1.16 (Tika 1.x end-of-life)
	pdfbox	2.0.6
	opencsv	3.3 **and** 2.0 (both bundled)
	commons-csv	1.0
	commons-lang3	3.4
	jsoup	1.11.3
	thucydides-core (for its word inflector)	0.9.275

Area	Library	Version
	guava	26.0-jre
Images / OCR	aws-java-sdk-textract / core	1.11.637 (AWS SDK for Java v1, end-of-support)
	tesseract-platform (JavaCPP)	4.0.0-rc2-1.4.3
	leptonica	1.76.0-1.4.3
	javacpp	1.4.3
	opencv (openpnp)	3.2.0-1 (no ARM binaries)
	imgscalr-lib	4.2
	jai-imageio-core / jpeg2000	1.3.1 / 1.3.0
	levigo-jbig2-imageio	2.0
Email	sendgrid-java / java-http-client	4.3.0 / 4.2.0
Logging	logback-classic	1.1.11
Testing	spring-boot-starter-test	1.5.6 (managed)

Frontend (`VIR-Frontend`): resolved versions

Area	Package	Version
Framework	@angular/core, common, compiler, forms, http, router, animations, platform-browser(-dynamic)	4.4.7
	@angular/cli	1.7.4 (webpack 3)
	@angular/compiler-cli, language-service	4.4.7
	rxjs	5.5.12
	zone.js	0.8.29
	core-js	2.6.12
UI	@ng-bootstrap/ng-bootstrap	1.0.0-beta.6
	Bootstrap (via the seed template's SCSS)	4.0.0-alpha.6 (per the frontend README)
	font-awesome	4.7.0
	popper.js	1.16.1
	chart.js / ng2-charts	2.9.4 / 1.6.0
	ngx-infinite-scroll	0.8.4
	ng2-simple-timer	1.3.5

Area	Package	Version
i18n	@ngx-translate/core / http-loader	7.2.2 / 0.1.0
Utilities	crypto-js / @types/crypto-js	3.3.0 / 3.1.47
	crypto-browserify, buffer	3.12.1, 5.7.1
	xlsx	0.16.9 (abandoned on npm; known vulnerabilities)
	file-saver	2.0.5
	google-translate-api	2.3.0
	angular-1.6-cli	1.6.3 (unused)
	mocha	5.2.0 (unused at runtime)
Styles	node-sass	original dependency (see 7.1)
Tests / lint	karma 1.7.1, karma-chrome-launcher 2.1.1, karma-cli 1.0.1, karma-jasmine 1.1.2, karma-jasmine-html-reporter 0.2.2, karma-coverage-istanbul-reporter 1.4.3, karma-html-reporter 0.2.7, karma-junit-reporter 1.2.0, jasmine-core 2.6.4, jasmine-spec-reporter 4.1.1, @types/jasmine 2.5.45, protractor 5.1.2, ts-node 3.0.6, tslint 5.3.2, codelyzer 3.0.1, uglify-js 2.8.29, @types/node 6.0.118	
Language	typescript	2.3.4

52 direct packages in total.
